

Assignment: Statement of Applicability

Statement of Applicability

- It is required for the certificate and it's to tell that which controls are and aren't applicable to the organization's ISMS
- Any control which excluded will be asked why and why for those you chose for your ISMS too. List of controls org selected to mitigate risk and state whether they fully implemented yet

Why is it matters

Just reason why you chose not to implement and implement to fulfil the requirements

It helps with risk assessment to security control

To address and respond to a threat which in identification step with treatment plan which is to implement security control to mitigate the risk

Easier time with auditor

Auditors know your objectives and aim to review and improve the ISMS. Data of SoA must match with the certification and always up to date

Provide Detail

Know why need to be implemented, for what and the how it works which can help mitigate risks you are aiming

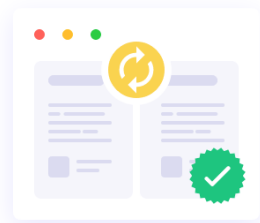
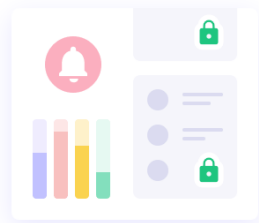
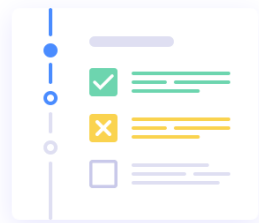
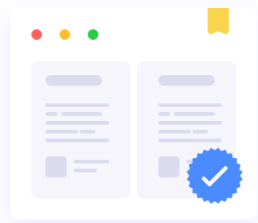
Statement of Applicability Document Sample:



ISO 27001
Statement of Applicability

How to write ISO27001 SoA

A step-by-step process for creating an ISO 27001 Statement of Applicability



- **Step 1: Conduct a risk assessment**
Identify and prioritize risks to your ISMS.
- **Step 2: Create a risk treatment plan**
Determine whether you will address or accept each identified risk.
- **Step 3: Choose your security controls**
Use Annex A and ISO 27002 to decide which controls are appropriate for protecting your ISMS.
- **Step 4: Justify your decision to exclude any controls**
Document your reasons not to implement any Annex A controls.
- **Step 5: Write your Statement of Applicability document**
Build your document listing the Annex A controls and implementations/justifications.
- **Step 6: Update your Statement of Applicability**
Keep your Statement of Applicability up-to-date with any changes to controls.

1. Identify and analyse risks to your ISMS

With all risk listed, know which one to prioritize based on likelihood and impact both assigning with a risk treatment to the risk owner and plan to close the VA

2. Define your risk treatment plan

Come up with security measure and document of the process with mitigating the risk and expected timeline to remediate any nonconformities. 4 standard risk treatment options:

- Mitigate with control to reduce likelihood or impact
- Avoid risk where it could happen
- Transfer the risk to insurance or 3rd party
- Accept risk when it's in risk appetite range

3. Select security controls from Annex A

Use control from Annex A to mitigate (weak password: strong password policy)

4. Justify any excluded controls

List down the control which you exclude on the SoA to show auditor the reason and that you are aware of the risk, just not applicable to your organisation

5. Complete your Statement of Applicability document

The Statement of Applicability lists all 93 Annex A controls, states whether each control is applied or not, explains why, shows related requirements (legal, business, compliance, etc.), and includes the implementation date

Annex A Control	Title	Control Objective	Control Applied?	Control Notes and Details	Control Requirement	Control Owner	Justification for Exclusion	Date of Implementation	Date of Last Assessment
5	Information security policies								
5.1	Management direction for information security	Provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.							
5.1.1	Policies for information security	A set of policies for information security shall be defined, approved by management, published, and communicated to all employees and relevant external parties.	Yes	↓ Policies are published in Rippling	Business requirement	↓ HR		1/1/22	3/1/22
5.1.2	Review of the policies for information security	The policies for information security shall be reviewed at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy, and effectiveness	Yes	↓ Fully implemented. Included in formal Annual Review process	Business requirement	↓ HR		1/1/22	3/1/22
6	Organization of information security								
6.1	Internal organization	Establish a management framework to initiate and control the implementation and operation of information security within the organization.							
6.1.1	Information security roles and responsibilities	All information security responsibilities shall be defined and allocated	Partial	↓ Currently documenting in org chart and role descriptions	ISO 27001 requirement	↓ IT & Compliance		ETA 12/31/22	
6.1.2	Segregation of duties	Conflicting duties and areas of responsibility shall be segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the organization's assets	Not Applicable	↓	Control not applicable	↓	No conflicting duties or areas of responsibility within the organization		
6.1.3	Contact with authorities	Appropriate contacts with relevant authorities shall be maintained	No	↓ This will be part of CISO role once hired	ISO 27001 requirement	↓ Upper Management		ETA 12/31/22	
6.1.4	Contact with special interest groups	Appropriate contacts with special interest groups or other specialist security forums and professional associations shall be maintained	No	↓ This will be part of CISO role once hired	ISO 27001 requirement	↓ Upper Management		ETA 12/31/22	
6.1.5	Information security in project management	Information security shall be addressed in project management, regardless of the type of project.	Yes	↓ Included within the project planning template	Contractual requirement	↓ All Employees & Contractors		1/1/22	3/1/22
6.2	Mobile devices and teleworking	Ensure the security of teleworking and the use of mobile devices.							

SoA must include:

- **Control ID:** The Annex A identifier (e.g., A.5.1)
- **Control Name:** The name or short description of the control
- **Implemented?:** Yes / No / Not Applicable
- **Justification:** Why the control was or wasn't selected
- **Implementation Status:** Fully implemented, partially implemented, planned
- **Control Owner:** Person or role responsible
- **Implementation Date:** When the control was implemented
- **Last Reviewed:** When the control was last evaluated
- **Requirement Type:** Whether it supports a legal, contractual, business, or other requirement
- **Related Risks:** Reference to risk treatment or risk register (optional)

6. Keep your Statement of Applicability up to date

The Statement of Applicability must be kept updated regularly. As the organization improves its ISMS, controls may be reviewed, added, changed, or removed over time. Regular management reviews ensure the SoA reflects the current security controls in use.